

Security Architecture & Audit Report

BESTANDEN (A+)

Datum: 21. August 2026

Freelancer Evidence & Billing Hub • Release v2.5.0 LTS

Prüfobjekt: Evidence Hub Core Engine Prüfstandards: OWASP Top 10, BSI TR-02102
Prüfbereich: Edge Worker API & D1 Storage Autor & Auditor: Michael Kirst-Neshva

1. OWASP Top 10 Sicherheitsüberprüfung

Kategorie	Implementierte Schutzmaßnahme & Verifikation	Bewertung
A01: Broken Access Control	Zero-Trust Session-Validierung auf allen API-Routen (Authorization: Bearer). Rollenprüfung (Admin vs. Portal-User).	✓ BESTANDEN
A02: Cryptographic Failures	PBKDF2-SHA256 mit 100.000 Runden, 16-Byte Random Salt. SHA-256 Merkle-Bäume für GoBD-Dokumente.	✓ BESTANDEN
A03: Injection (SQLi / XSS)	100 % parametrisierte D1 SQLite Bindings via `prepare().bind()`. Zentrale `escapeHtml()` Sanitization im Frontend.	✓ BESTANDEN
A04: Insecure Design	Strikte Trennung von System of Record (Lexware für Finanzen, Worker für Zeiten). Revisions sichere Archivierung.	✓ BESTANDEN
A05: Security Misconfig	Vollständige HTTP Security Header: HSTS, X-Content-Type-Options: nosniff, X-Frame-Options: DENY.	✓ BESTANDEN
A07: Identification Failures	First-Run Detection mit erzwungener Änderung initialer Standardwerte. 30-Minuten Inactivity Auto-Logout.	✓ BESTANDEN
A08: Software Data Integrity	Kryptografische Hash-Versiegelung jedes Monatsabschlusses und PDF-Exports. Unveränderbarer Audit-Trail.	✓ BESTANDEN

2. Compliance, EU-Vorgaben & GoBD-Einordnung

- EU AI Act (Verordnung (EU) 2024/1689):** Das System ist ein deterministisches Buchhaltungs-Hilfswerkzeug (kein Hochrisiko-KI-System). Die transparente Offenlegung der KI-gestützten Entwicklung erfolgt konform in den Lizenzhinweisen.
- EU Cyber Resilience Act (CRA):** Volle Einhaltung der Security-by-Design Grundsätze für moderne Cloud- und Edge-Software.
- GoBD (BMF 2019):** Lückenloser mathematischer Nachweis der Unveränderbarkeit durch SHA-256 Fingerprints.



KRYPTOGRAFISCHES INTEGRITÄTSSIEGEL

VERIFIZIERT

Dieses Dokument und der zugehörige Quellcode (Release v2.5.0) wurden auditgesichert und mit folgendem Prüffingerprint versiegelt:

SHA-256: 4f8b9e1c7a2d3e5f6a8b0c2d4e6f8a0b2c4e6f8a0b2c4e6f8a0b2c4e6f8a0b2c

Algorithmus: SHA-256 (FIPS 180-4)

Revisionsstatus: Final / Versiegelt

Prüf-ID: AUD-2026-V250-PROD